AFRICLUB

Production-readiness investigation and remediation plan

27 September 2026 | Authoritative Google Drive workspace

NO-GO FOR FULL PRODUCTION MIGRATION

Contain unsafe sharing. Reconcile the actual executable source. Prove complete journeys in the target runtime before activating financial or native releases.

24 findings

Current-source and evidence-led assessment

130 tasks

Owners, dependencies and closure criteria

512 tests

Executed here; not full release certification

Security-sensitive report. Restrict access to named project stakeholders. No secret values, signing-key material or production personal-data exports are included.

Read together with the task workbook, source register and reproducible evidence package. No production or repository permissions were changed by this assessment.

Assessment date: 27 September 2026 | Target: authoritative AFRICLUB Google Drive workspace

Decision: NO-GO for full production migration or a general five-club financial launch.

This is an evidence-led engineering assessment, not a penetration-test certificate, a legal opinion, or confirmation of the live state of a production account. It separates the current files inspected in Drive from archived implementation packages, dated infrastructure observations, newly executed local tests and external platform requirements. The accompanying register contains **130 proposed tasks**, **24 findings**, role owners, closure dependencies and acceptance evidence. No production configuration, repository file, permission, payment or membership was changed during this investigation.

Executive decision

AFRICLUB has a credible shared-package architecture and meaningful transactional foundations. It does not yet have one demonstrated, integrated and operationally accepted release candidate. The main problem is now **convergence and proof**, not a lack of generated code: some improvements exist only in archives or revised sibling files; active source still contains known defects; new identity, payments and native adapters are deliberately disabled or unconnected; important end-to-end operational paths remain incomplete. A complete archive upload preserves work but does not resolve those issues. [S01–S15, S32–S34, E02]

The highest-priority finding is independent of the Cloudflare migration. Fresh Drive metadata returned `type=anyone`, `role=writer`, `allowFileDiscovery=false` for the AFRICLUB root, an Android upload-keystore file and a web `.env.local` file. These are unsafe access-control observations. The review did not open their sensitive contents, test the key, attempt anonymous access, or establish malicious access. Nevertheless, confidentiality and source integrity require immediate containment and an exposure assessment. A link that is not discoverable through search is not a private resource. [E01, S30–S31, W01]

Recommended direction: secure the workspace; establish and merge one canonical candidate; prove a small complete journey in the actual target runtime; then extend scope under explicit release gates. Preserve the current source writer until a rehearsed one-writer cutover is approved. Do not activate disabled flags just to make staging code appear complete. Do not replace Flutter or move directories wholesale while the integration and evidence gaps remain. [S19, S22, S13; recommendations]

The decisions management should make now

Decision	Recommendation	Evidence needed to change the decision
Repository sharing	Restrict to approved named users/groups and investigate exposure.	Fresh ACL readback, artifact classification, incident review and appropriate secret/key remediation.
Full platform production readiness	No-go.	Exact candidate plus all relevant security, data, device, financial, operational and commercial gates.
Read-only public pilot	Potentially the first limited release, but not approved today.	Reconciled reader, complete approved snapshot, rights, domains, security and operating acceptance.
Membership/payment rollout	Keep the target disabled pending end-to-end proof.	Real provider evidence, historical claims, current entitlement, recovery and signed-client acceptance.
Predict/FET transaction enablement	Keep unresolved mechanics disabled.	One approved economic/territory contract aligned with API, ledger, copy, tests and store policy.
Supabase retirement	Not authorized by this evidence.	Full caller/object disposition, consistent restore, reconciled obligations and observed single-writer cutover.

1. Method and assurance boundaries

What was inspected

The investigation traversed the named Drive workspace and reviewed selected high-leverage files: the root manifest and README; architecture, migration inventory, release and FET policies; main CI and web deployment workflows; original/revised validator and public-worker paths; web dependencies and Next.js security configuration; identity, checkout and allocation service cores; membership gateway and operator console contracts; design-evidence registries; and metadata for sensitive artifacts. The complete conversation collection and prior implementation reports were treated as preservation and historical evidence, not automatically as the current executable tree. [S01–S34]

A bounded Drive-root listing was marked potentially incomplete. The review used the exact AFRICLUB folder and targeted traversal for relevant subfolders; it does not claim an exhaustive recursive enumeration or line-by-line audit of every application file. No secret value, signing key material or production personal-data export was opened. Permission observations record exact queried IDs without assuming that every permission was inherited from the same parent. [E01]

What was executed in this review

Evidence	Actual execution	What it does not prove
Payment and checkout regressions	432 passing tests in a reconstructed source/test subset.	Current full-repository CI, genuine D1 or provider settlement acceptance.
Authentication regressions	77 passing tests in that subset.	Production identity provisioning, carrier delivery or native credential security.
New behavior reproductions	Three passing tests reproduced two public-reader issues and the shared OTP budget.	A demonstrated production incident or exploitation.
Boundary validator	Valid minimal Git fixture passed; adding the exact current inventory document failed the lexical rule.	The result of a full live CI run.
Source comparison	Three freshly downloaded critical service cores matched the test context; three canonical files differed from proposed Batch 1 replacements.	A complete source-tree equivalence proof.
Dependency consistency	Package root dependencies matched the lockfile root.	Absence of vulnerabilities, license problems or transitive supply-chain risk.

512 code tests passed in this investigation: 432 + 77 + 3. The three new tests are tests of observed weaknesses, not fixes. Earlier totals such as 894 or 962 are historical batch results and are not added to this review's total. The portable native suites were not rerun here. The actual downloaded code and reproduction scripts/logs are provided in the evidence package. [E02–E07]

The local Node runtime was 22.16.0, below the web package's declared minimum of 22.22.2. Consequently, these targeted Node tests are not represented as a compliant full web build. Full Dart/Flutter builds, Apple/Android hosts, signed binaries, real Access, real Workers/D1/R2, pgTAP across a clean target, physical devices, production load, live provider health, branch protection and cloud-account settings were not verified. [S08, S22, E05–E07]

Six states that must remain separate

A file can be **archived**, **installed in canonical source**, **locally tested**, **integrated into the application**, **deployed**, or **accepted for production**. These are separate assertions. Every release record should identify the source hash, environment, artifact, test scope, observer and timestamp for the particular assertion. A report saying “implemented” cannot stand in for all six.

2. Current platform status

Area	Evidence-supported status	Production implication
Shared Flutter workspace	Five registered club shells and configuration packages, with useful core/data/feature boundaries.	Preserve the architecture; support registration is not release certification.
Existing Supabase-backed product	Current source still references Supabase; dated records identify it as the authoritative writer. Today's remote availability was not tested.	Do not remove it or infer restored access from local tests.
Cloudflare public reader	Original entrypoint remains present; improved sibling/archive versions coexist. Fresh tests reproduced freshness/media weaknesses.	Reconcile and verify before a public-content pilot.
Operator publication service	API, private publisher and console pieces exist. Console-specific wrapper/config named by documentation were not returned in the inspected folders.	Assembly and real Access/PWA journey remain unproved.
Supporter identity	Custom OTP/session implementation is present and locally testable; deletion is asynchronous and incomplete beyond its request.	Operational recovery, abuse, keys, profile migration and client integration remain.
Membership checkout/allocation	Server-owned offer selection, immutable snapshots, idempotency and atomic membership effects exist in isolated staging.	Good transaction core; not a complete live payment service.
Contributions, groups, tickets, shop	Existing product scope remains; the new allocation service does not complete every downstream business effect.	Complete each port or exclude it explicitly from enabled release scope.
Native client/recovery	Dart, Android and iOS candidate components exist across current source and archives. Actual hosts/secure stores and all club integrations remain unaccepted.	No signed-client readiness claim follows from portable JVM/Swift tests.
Design and release evidence	Checklists are detailed; two current evidence registries are empty and structural CI expects incomplete design flags.	Governance structure is present, but it is not completed acceptance.
Operations and legal	Disabled templates and explicit gates prevent premature enablement. Supporting production approvals were not demonstrated.	Keep gates; supply evidence and operating ownership rather than bypassing them.

The five products are Vital'O, Rayon Sports, Nkana, AS Vita and Costa do Sol. The dated inventory marks only Rayon active/onboarded. That does not justify deleting the other shells, and it does not establish their readiness today. Costa's documented remaining identity, merchant/route and reserved-tenant-ID checks require explicit closure. Use a five-club by surface/platform matrix, not one global “done” flag. [S01–S02, S06, S11, S13, S32–S33]

3. Security containment and source integrity

F01 — unsafe sharing is the first release blocker

The root and the two queried sensitive artifacts reported link-holder writer permission. There are two distinct risks: reading material that may contain secrets, and modifying source/configuration/evidence subsequently trusted by the team. Strong application authorization does not protect a release built from an untrusted source workspace. [E01, W01]

Contain access while preserving the evidence needed to understand what happened. Enumerate actual effective permissions, including direct grants, descendants, archives and copied files. Review access/revision logs where available. Classify whether the keystore is currently used and whether .env.local contains live confidential values. A Supabase publishable/anonymous client key is not equivalent to a service-role secret; do not rotate every visible string indiscriminately. Conversely, a signing/upload key is not made safe by being excluded from Git if its Drive copy is openly shared. [S30–S31; recommendations]

Where live secret exposure is established or cannot reasonably be excluded, use provider-approved revocation/rotation or upload-key reset, and verify clean signed builds afterward. Distinguish the upload key from the app-signing key and preserve release continuity. Do not delete files or reset credentials as an unreviewed side effect of this report. Tasks SEC-01 through SEC-10 define containment and evidence.

F02–F03 — build one candidate, not a pile of patches

Fresh byte comparisons found the active root manifest, boundary validator and public reader different from the first archived implementation payload. The directory also contains .revised-20260926 alternatives. Main CI calls the original validator. This is a concrete case where prior successful patch tests do not establish that the tested behavior is installed. [S02–S05, S07, E02]

The original validator passed the synthetic preservation baseline but rejected the exact current migration inventory when added to it. Its lexical bans treat necessary legacy-object names in evidence like forbidden runtime ownership. A narrow approved exception system can solve that without allowing retired features back into production. The correct change is not to disable the gate, remove the inventory, obfuscate names, or exclude all documentation. [S05–S06, E03]

Establish a protected Git candidate and merge reviewed changes against current hashes. Classify each archived path as accepted, superseded, missing, intentionally deferred or evidence-only. Remove generated directories from tracked source only after inspecting Git's actual tracked-file list; their presence in a Drive export alone does not prove they are committed. Store archival packages outside the build context. Tasks REP-01 through REP-10 own this work.

4. Runtime and delivery correctness

F04–F05 — public snapshots are not safely published in the active reader

The active reader calculates freshness from the maximum capture timestamp across all source records. In the local reproduction, an old snapshot was rejected, but the same old news was returned successfully once an unrelated record made the global maximum current. This is a risk when partial imports can coexist; it is not proof that production currently imports that way. [S07, E04]

The media branch runs before that freshness check. Its current implementation selects a SHA-256 value but checks only object presence/size before serving. The reproduction supplied known-incorrect digest metadata and matching-size bytes; the response still succeeded. This does not prove malicious content exists, but it shows why a manifest hash alone is not a read-time integrity control. [S07, E04]

Use a complete immutable snapshot with validated source counts, rights and media hashes, then atomically switch an approved active pointer. Bind every public response and asset to the intended snapshot. Define whether media has the same freshness requirement or a separate revocation policy, and test CDN cache behavior under rights withdrawal. Preserve the existing separation between public discovery and financial mutations. Tasks WEB-01/02 and DAT-07/08 are release prerequisites.

F06–F08 — workflow assembly needs independent proof

The main CI already includes substantial Flutter, web, database and security checks. That is valuable. The inspected deployment workflow, however, independently triggers on main/manual execution, installs/checks dependencies, runs an OpenNext build and deploys. It does not itself establish dependency on all required test/type-check results. Next.js is configured to ignore build-time TypeScript errors because a separate type-check is intended to be authoritative. Actual branch protections may mitigate this, but they were not inspected; the workflow source alone does not prove the constraint. [S03–S04, S08–S09]

Next.js documents that ignoring build errors needs separate assurance. Use protected promotion of the exact tested artifact, not a second unbound rebuild. Pin third-party action revisions, restrict tokens, record migrations and config fingerprints, and require protected environment approval. The main CI must also run current Cloudflare and portable/native suites; older local test totals are not a durable integration gate. [W10, W13; QAT-01/02/07]

The operator console has a more specific assembly mismatch. `CONSOLE.md` names `wrangler.console.staging.jsonc` and `src/console-worker.mjs`; those were not returned in the inspected current root/source lists. The current API config selects `src/index.mjs`, which exposes the API-only routes and does not call the separate console handler. Reconcile the intended wrapper, assets, APIs and admin launcher before claiming the UI is available. Cloudflare's `ctx.access` interface is current and valid; the risk is untested integration and invocation/context rules, not that this interface is invented. [S23–S27, W08]

5. Identity, revocation and payment recovery

F09 — authentication fairness is a production requirement

The current identity code applies a ten-per-minute global challenge-creation budget in the same set as IP and phone limits. Ten synthetic requests at one club consumed the shared capacity; the next request at another club was rejected. This is a pilot constraint, not evidence of sustainable multi-club match-day authentication. [S10, E04]

Do not simply remove throttling. Design hierarchical limits: per verified account/phone, per ingress source, per club, plus an explicit global provider-cost and safety ceiling. Measure shared-network effects, resend fairness, challenges for unknown users, provider degradation and support load. A valid security limit can still be an avoidable noisy-neighbor denial of service. [AUT-01/02, OPS-01/09; recommendation]

F10 — define exactly when revocation takes effect

The gateway derives the user from the private identity verifier, checks ownership before broader receipt reads and verifies the token around upstream work. Those are useful controls. Its documentation correctly states that two databases are not one transaction: a checkout may commit while later identity rechecking withholds its response. The outcome is unknown, not rolled back. [S11]

Specify an authorization acceptance point for each operation. Creating a pending checkout, reading a receipt, allocating verified money, issuing a ticket and approving a refund do not have the same risk or fencing needs. Co-locate authority when strict atomic guarantees are necessary, or adopt a reviewed epoch/fence protocol with clearly bounded semantics. Do not demand an impossible atomic transaction with a carrier; keep external action uncertainty distinct from database authorization. [ARC-03, AUT-06; recommendation]

F11, F17–F18 — secure local state is necessary but insufficient

The new native recovery stores protect pending markers and coordinate concurrent local work. They are not protected credential suppliers. Prior reports explicitly separate tested portable engines from uncompiled Android/Apple hosts and absent Dart/Flutter/device acceptance. Installing a Kotlin/Swift source file or running Linux tests cannot certify Android Keystore, Apple Keychain, entitlements or a Flutter method channel. [S32–S33]

Uninstalling or clearing all app data can remove both a key and its reservation file. A fresh local store cannot prove that a previous payment did not occur. Add server-authoritative recovery for outstanding orders/attempts, and a governed late-payment resolution process. Do not unlock another payment merely because the original order expired, a handset returned to the app, or the dialer reported that it opened. [S11, S32–S33; MOB-06, PAY-02]

The identity deletion endpoint revokes sessions, creates a request/outbox event and returns `pending_external_erasure` with `erasureCompleted:false`. That honest response is good; it does not finish deletion. Build processor-aware erasure, lawful-retention exceptions, status and failure recovery. Apple's account-deletion guidance distinguishes genuine deletion from simply deactivating an account. [S10, W16]

6. Financial and database architecture

What is worth preserving

The current checkout selects prices and recipients server-side. The allocation service binds evidence to an immutable order, checks club/owner/provider/amount/currency/recipient, protects provider references globally and supports original-result recovery. Membership renewal preserves existing identifiers and administrative suspension. Local tests cover many rollback and concurrency scenarios. These are substantive controls, not mere scaffolding. [S13–S15, E05]

F12–F14 — close the settlement and business-effect gaps

The same source explicitly says a digest or `attestationRef` is provenance, not proof of settlement. The trusted ingress/reconciler must establish authenticity using approved provider or receiving-account evidence. A delivery receipt for a WhatsApp login code is not payment evidence. Even a genuine debit notification can require correct receiver, value, time and duplicate-reference reconciliation. [S13]

Contribution allocation currently returns `businessTargetFulfilled:false`; totals, rewards and referrals are not all performed. Refunds, reversals, group contributions, stock/ticket/shop commands and complete outbound effects remain separate. Finish them, or disable the affected product scope through server and client guards. Never relabel an allocation-only record as a completed contribution. Current entitlement must remain distinct from a historic membership receipt. [S13–S15]

The global used-reference store must include the reconciled history across every affected target and club. Starting a new writer with only recent history can permit a previously consumed payment to be reused. A per-club database split would remove the existing cross-club uniqueness constraint unless a separately proven global authority replaces it. [S13]

F15 — keep Cloudflare, but prove the persistence decision

D1 supports transactional batches, but PostgreSQL behavior does not transfer merely because statements are rewritten as SQLite. The reviewed D1 documentation specifies a 10 GB paid-plan per-database limit, query/bind limits and sequential execution within a database. Test the actual trigger-heavy transaction on D1, under simultaneous allocations, expiry waits and failures. Local SQLite threads are necessary evidence, not a substitute for the target runtime. [W02–W03, W05–W06]

My recommendation is to retain Workers as the API/orchestration direction and make the final transactional datastore decision after measured correctness, workload, locality and operational evidence. An all-D1 design may be viable for the approved workload. If it fails a hard requirement, choose an appropriate relational authority without discarding the client contracts or global deduplication invariant. Do not introduce a second financial authority in a Queue or Durable Object as a workaround. [ARC-01/02/07/10; recommendation]

Model budgets using explicit assumptions: simultaneous active supporters, read/write mix, cache hit rate, OTP bursts, provider retry rate, database rows touched, object traffic and human exceptions. Approve latency/error/availability targets per journey and test overload behavior. A checkout should fail transparently rather than allocate twice. No revenue, cloud bill or completion percentage is estimated from unsupported user-volume assumptions.

Backup and cutover

The 25 September continuation documents valuable export and restore work, but says the archive plus cron segments is not the final transactionally consistent snapshot. It also distinguishes eight unresolved AFRICLUB media originals from eleven separately recovered Gikundiro public assets. These are dated observations; current provider access and recovery progress must be checked afresh. Supabase's database backup documentation separately confirms that Storage object originals are not in the database backup. [S06, W09]

Before switching writers, reconcile IDs, financial totals, pending and fulfilled obligations, member terms, stock, tickets, provider-reference claims, object bytes and rights. Rehearse a write freeze or controlled delta strategy. After the target accepts financial writes, rollback cannot mean simply sending traffic to a stale source database. Preserve original receipts and use a documented forward-reconciliation or consistent-restore strategy. [DAT-04–10, REL-05/06; recommendation]

7. Product, UX, administration and content

F19 — resolve economics, not just terminology

The blueprint/FET policy describe free selected-match predictions. The older implementation guide describes a 100-FET entry debit, 500-FET welcome grant and pool distribution. A newer decision gate makes the conservative free-entry contract authoritative pending approval. Preserve that gate and history; it does not alone establish that every API, trigger, client and environment follows the approved rule. [S16–S19]

The commercial/legal classification depends on mechanics, territory, entry consideration, redemption and rewards—not merely calling a token a point or avoiding betting language. Qualified review is required for enabled markets. The report does not conclude that AFRICLUB is gambling, licensed, exempt or unlawful. Use approved terms, authoritative result finality, cancellation/void rules, age/territory controls where applicable and one traceable settlement implementation. [W15; REG-08, PRD-01/02]

F20–F21 — finish real journeys and truthful states

Current route-state and evidence-bundle registries are empty. That does not prove there are no screenshots elsewhere, but it means these registries do not demonstrate accepted coverage. Main CI's expectation of incomplete design flags must not be presented as a design-complete check. Test the actual candidate: account switch, weak network, stale membership, unavailable provider, unknown payment, accessibility, data export, account deletion and staff denial. [S03, S20–S22]

Apply WCAG 2.2 AA as a web acceptance baseline, complemented by TalkBack/VoiceOver, Dynamic Type/large text, keyboard focus, reduced motion, contrast and touch-target checks. The requested design skill should be the explicit authority with a versioned football-product adapter; reference aesthetics do not

justify confusing balances, hidden terms or a payment success message based on dialer launch. [W14; PRD-04/05, QAT-08]

The product boundary also needs an explicit browser decision. The current blueprint describes authenticated web membership and contribution initiation, whereas parts of the release material describe public web as discovery-only. The new native gateway deliberately rejects browser cookies and Origin headers; it is not a migrated browser session architecture. Decide the supported browser journeys, then implement CSRF-protected sessions or exclude those journeys explicitly. [S01, S11, S19, S22]

The admin PWA requires much more than a publication screen: per-club permissions, finance/support/content roles, approved corrections, controlled exports, user support, event/reconciliation queues and audit search. Review versus publish is not necessarily maker/checker; the console documentation allows the same person to do both. Use separation of duties where the business risk warrants it, not as an unsupported blanket claim. [S26; WEB-05/06]

White-label and football quality

Five shells need five approved tenant/branding/merchant mappings and ten mobile platform release dossiers. Confirm real developer-account authority, domains, legal/support identity, privacy disclosures and content ownership for each. Apple's template-app rule is relevant to who submits a white-label app and whether it delivers genuine differentiated functionality; a shared codebase alone does not settle acceptance. Guideline 4.3 also specifically cautions against duplicative sports-team variants. Document meaningful club differentiation and the submission strategy; consider an aggregated alternative only through an explicit product decision. [S01–S02, W15]

Treat fixtures/results as governed data: external IDs, competition seasons, timezone, postponements, abandoned/void matches, duplicate updates, official-result corrections and settlement finality. Maintain licensed feed and image rights, player/minor consent where relevant, expiry and cache withdrawal. Set a club-approved language policy rather than silently changing the existing localization contract during a backend migration. These are release work packages, not assertions that every existing screen is defective. [S19, PRD-02/03/07]

8. Privacy, platform policy and operational readiness

F16 — residency must be an architecture input

Cloudflare's current D1 location documentation says databases do not run in Africa and that a location hint is not a placement guarantee. Jurisdiction restrictions and Worker execution locations are also distinct. Therefore, “runs on Cloudflare” must not be interpreted as “stores Rwanda user data in Rwanda.” [W04]

Rwanda's official law text distinguishes Article 48 transfer grounds from Article 50 foreign-storage authorization. For relevant personal-data processing, validate controller/processor registration, the actual authorization certificate, the processor chain and the intended database/replica/log/backup locations before import. The existence or absence of certificates was not established from this repository. Counsel must assess applicability and current conditions; this report is not a legal compliance opinion. [W19–W23]

Complete a separate launch assessment for Burundi, DR Congo, Zambia and Mozambique, including privacy/transfers, consumer rights, payments/merchant structure, tax/receipts and prediction/reward restrictions. This review did not resolve all four national legal regimes; the register assigns explicit tasks rather than filling gaps with assumptions. [REG-03/04/05/07]

Apple currently requires iOS uploads to use the iOS 26 SDK or later from 28 April 2026. This is a build-SDK requirement, not a requirement to exclude users running the repository's older minimum deployment target. Also validate current Google Play target/API and deletion obligations at submission; the detailed

Google deletion page was rate-limited during this research, so that current check remains open rather than being derived from community answers. [W17; REG-10]

Classify membership benefits individually: a physical ticket, merchandise order and digital entitlement may have different store-billing treatment. Validate current platform/territory exceptions and actual benefits instead of assuming all memberships may use the same USSD route. [W15, W18; REG-08/10]

F22 — build an operating service, not only request handlers

The allocation outbox is a sound starting point, but it has no complete external dispatcher/dead-letter operating process. Queues have at-least-once delivery semantics; an acknowledgement does not establish an external effect happened exactly once. Deduplicate the effect in the consumer's own transaction, record provider state and support bounded retry and controlled re-drive. [S13, W07]

Add privacy-safe metrics, not raw payer payloads: authentication success and budget exhaustion by club, snapshot age, stale responses, allocation lag, unmatched payment age, pending erasure, outbox/DLQ backlog, ticket redemption conflicts, latency and resource saturation. Test alerts with a human responder and runbooks. Missing telemetry is not fixed by enabling unrestricted logs. [OPS-01–05; recommendation]

Define and rehearse RPO/RTO, backups of configuration and objects, key dependency recovery, seasonal/game-day spikes, provider outage behavior and support escalation. Finance and club operators should practice investigating a late payment or duplicate ticket without deleting a ledger record. Track unit costs through the entire journey, including provider messages and manual exceptions. [OPS-06–10; recommendation]

9. Prioritized execution and release gates

The accompanying workbook is the actionable backlog, not a completion scoreboard. It contains **37 P0 tasks, 91 P1 tasks and two P2 tasks**. P0 denotes urgent containment or a hard prerequisite for the affected release; it does not imply every task has the same incident urgency. P1 is required before the relevant scope goes live. P2 is post-acceptance improvement. Owners are role recommendations; named assignments and dates must be added by the team. All statuses are Open because no remediation was performed by this review.

Gate	Decision and closure standard	Principal task groups
G0 — contain and establish authority	Restrict unsafe access, assess credentials, preserve evidence, determine applicable privacy constraints.	SEC-01–06; REG-01; REP-01
G1 — converge source	One protected candidate, reviewed patch reconciliation, passing real-source validators, pinned tools, source/artifact manifest.	REP-01–10; QAT-01/02
G2 — prove foundations	Target-runtime transaction/auth/tenant correctness, data/claims/backup reconciliation, approved scope/economics and architecture.	ARC; DAT; AUT; PRD-01; REG
G3 — integrate and accept	Real client/provider/admin journeys; native platforms; security/accessibility; finance exceptions; operational drills.	PAY; MOB; WEB; QAT; OPS
G4 — controlled launch	Exact-artifact approval, rehearsed cutover and post-write rollback, supervised pilot, monitored expansion.	REL-01–08

Gate	Decision and closure standard	Principal task groups
G5 — retire safely	No remaining source dependencies or stranded obligations; retained archives restore; keys/jobs retired under approved retention.	REL-09/10

The practical critical path is **containment → canonical source → runtime/data proof → complete membership journey → supervised financial pilot → broader product/club expansion → source retirement**. Work on media, device builds, legal assessments and operations can proceed in parallel, but none substitutes for the relevant gate. No calendar commitment can responsibly be inferred without named staffing, access and production workload assumptions.

Workstream register

IDs	Workstream	Required owner role	Main outcome
SEC-01–10	Security containment	Security lead	Trusted source and credential boundary.
REP-01–10	Source convergence	Repository maintainer	Reproducible protected candidate.
ARC-01–10	Architecture and boundaries	Technical architect	Proven transaction, tenant and capacity decisions.
DAT-01–10	Data migration	Migration lead	Complete reconciled and restorable source/target data.
AUT-01–10	Identity and authorization	Identity lead	Secure, recoverable user/session lifecycle.
PAY-01–10	Payments and fulfillment	Payments lead	Authentic evidence, complete effects and governed exceptions.
MOB-01–10	Native completion	Mobile lead	Accepted Android/iOS integration for five clubs.
WEB-01–10	Public web and admin	Web/admin lead	Current public content and authorized browser operations.
PRD-01–10	Product/content/design	Product/design lead	Consistent mechanics, rights and truthful accessible states.
QAT-01–10	Assurance	QA/security lead	Exact-candidate release evidence.
OPS-01–10	Operations	SRE/operations lead	Monitored, supportable, restorable service.
REG-01–10	Legal/privacy/club approval	Privacy/legal lead	Applicable market/platform approvals.
REL-01–10	Launch and retirement	Release manager	Observed single-writer rollout and safe retirement.

Management controls for execution

Require a demonstration and inspectable closure evidence for each task. “File uploaded,” “unit tests pass,” “awaiting real test” and “feature flag available” are not synonyms for done. Link each resolved finding to its merge commit, runtime test, accountable approval and deployment readback. Use an independent reviewer for the most sensitive changes. Track unresolved production defects separately from source-cleanup work so visually impressive progress cannot hide payment or access-control risk.

A feature may be deferred only by explicitly excluding it from the release matrix, blocking server mutations and removing misleading client links. An incomplete contribution implementation cannot remain marketable as a working contribution product. A read-only site pilot cannot be announced as completion of the five-club membership platform. [S19, S22; recommendation]

10. Bottom line

Preserve the useful work, but stop treating batch output as release progress until it is reconciled and accepted. The platform has good modular and transaction design choices. The next investment should prioritize secure source control, target-runtime verification, end-to-end identity/payment recovery, actual native integration and operational/legal acceptance. The confirmed open-link writer permissions require action before relying on this folder as an authoritative production source.

The evidence supports a no-go for the full migration today. It also supports a practical route forward: converge and prove a small complete slice, then expand safely. It does not support a claim that the work must be discarded, that a native rewrite is necessary, or that all prior tests were meaningless.

Appendix A — finding register

ID	Priority	Finding	Evidence
F01	P0	Link-holder write permission on repository and sensitive artifacts	E01; S30; S31; W01
F02	P0	No reconciled single production candidate	S02; S05; S07; E02; S34
F03	P0	Current boundary validator rejects legitimate migration inventory	S03; S05; S06; E03
F04	P0	Public reader uses newest-row freshness rather than completed snapshot	S07; E04
F05	P1	Public media bypasses freshness and byte-digest checks	S07; E04
F06	P0	Deploy workflow does not establish candidate-wide required checks	S03; S04; S08; S09; W10; W13
F07	P1	New runtime/native suites are outside inspected main CI	S02; S03; E05; E06; W05; W06
F08	P1	Operator console documentation and installed entrypoints diverge	S23; S24; S25; S26; W08
F09	P1	Shared ten-per-minute OTP challenge budget	S10; E04
F10	P0	Session checks do not create cross-database revocation atomicity	S11; S13; W03
F11	P1	Account deletion stops at pending external erasure	S10; W16; W19; W23
F12	P0	Payment provenance is not settlement authenticity	S13; S15
F13	P0	Financial product migration is incomplete	S13; S14; S15
F14	P0	Historical claims and final consistent backup unproven	S06; S13; W09
F15	P1	All-D1 suitability is not yet production-proven	S13; S14; W02; W03; W04
F16	P0	Foreign storage authorization has not been evidenced	S10; S13; W04; W19; W20; W21; W22
F17	P1	Native adapters are not platform-accepted or integrated	S11; S32; S33; W12; W17
F18	P0	Local state loss leaves unresolved payment attempts unsafe	S32; S33; S11
F19	P0	Predict economics remain inconsistent with governing free-entry policy	S16; S17; S18; S19; W15
F20	P1	No completed integrated visual/accessibility evidence registry	S03; S20; S21; W14
F21	P1	Browser/member portal and broad admin migration remain separate	S01; S11; S19; S26
F22	P1	Operational delivery, monitoring and recovery are incomplete	S12; S13; W07
F23	P1	Five-club commercial/store readiness is not established	S01; S22; W15; W17; W18
F24	P1	Governance registers and documents do not reflect one current contract	S01; S19; S22; S28; S29

Appendix B — sources and execution records

Repository IDs refer to the inspected files. E-identifiers are the new local evidence files included in the evidence archive. W-identifiers are official external guidance reviewed on 27 September 2026; they do not prove AFRICLUB has implemented the requirement. Archived reports retain their historical status and are not deployment attestations.

S01 — Root README / supported surfaces and five clubs (Repository source). Freshly read from the current Drive file; not proof of deployment.

https://drive.google.com/file/d/1W-wB0714GR2PtTb01XldFYbQcFhL_1AC/view

S02 — Root pubspec.yaml / workspace and toolchain (Repository source). Freshly read from the current Drive file; not proof of deployment.

https://drive.google.com/file/d/1NBjccCUL0GExYKlWVsGptSv3TttePFa7/view

S03 — Main CI workflow (Repository source). Freshly read from the current Drive file; not proof of deployment.

https://drive.google.com/file/d/1vza_RNiaP7bOgavHdtYifYUk4uYBoOXM/view

S04 — Web deployment workflow (Repository source). Freshly read from the current Drive file; not proof of deployment.

https://drive.google.com/file/d/1JriJdKI5ZI66Zb0tcrD49U8vIXdk9_su/view

S05 — Original repository boundary validator (Repository source). Freshly read and exercised in a minimal disposable Git fixture.

https://drive.google.com/file/d/1N23TLa4JwiI46dPwiWV3ODcISwmOJBRX/view

S06 — Stage-0 inventory, including 25 September continuation (Repository source). Freshly read; infrastructure observations are dated 24–25 September, not independently rechecked production facts.

https://drive.google.com/file/d/1-7B4JcFcWG3OrLUhBamPvNLURFKqU5Kl/view

S07 — Current public-content Worker entrypoint (Repository source). Fresh bytes; two isolated tests reproduced freshness and media-verification behavior.

https://drive.google.com/file/d/11HjHNGCFck0SiQGNHOWljw4Q-nxeMIPw/view

S08 — Web package.json (Repository source). Freshly read from the current Drive file; not proof of deployment.

https://drive.google.com/file/d/1P7Dd9dMO4dT35M-va4qQIYwTgLVFUeCy/view

S09 — Next.js configuration (Repository source). Freshly read from the current Drive file; not proof of deployment.

https://drive.google.com/file/d/1ylTZbAFeURan9Rk_8oJwsqd1YOKJDtAM/view

S10 — Supporter IdentityService (Repository source). Fresh bytes match archived test context; shared OTP-budget behavior reproduced using local SQLite.

https://drive.google.com/file/d/1nZBkMaq85TVbCtagt109zHTRYm3Q1K7Y/view

S11 — Supporter membership gateway README (Repository source). Freshly read from the current Drive file; not proof of deployment.

https://drive.google.com/file/d/1ZMOX3aVmWujKCYV_YahrkQ5NPbFXuY7h/view

S12 — Supporter membership gateway disabled configuration (Repository source). Freshly read from the current Drive file; not proof of deployment.

https://drive.google.com/file/d/1AETDVu4czZPLBw5yMVdkGEOgCX_X4S05/view

S13 — Payment-allocation README (Repository source). Freshly read from the current Drive file; not proof of deployment.

https://drive.google.com/file/d/11c2iijJkMgVqUIhC9JivYi8vxb5prAsr/view

S14 — Membership checkout service (Repository source). Fresh bytes match archived test context; 432 payment/checkout regression tests rerun in reconstructed subset.

https://drive.google.com/file/d/1IQ0j1CbRMRzrL8sb8pn-CmldmL95UOar/view

S15 — Payment allocation service (Repository source). Fresh bytes match archived test context; not a live provider test.

https://drive.google.com/file/d/1cpCkpbugLJhfNBkE2aPYmFQhawKvTHdb/view

S16 — Predict economics decision gate (Repository source). Freshly read from the current Drive file; not proof of deployment.

https://drive.google.com/file/d/17ycbTO5tfhGoKOFEnqrDMmIud2MmIQWJ/view

S17 — FET ledger and rewards policy (Repository source). Freshly read from the current Drive file; not proof of deployment.

https://drive.google.com/file/d/1HhucygDrFRiVp97oEdhhvlBfFsT2w8O4/view

S18 — Historical simplified Predict migration guide (Repository source). Historical behavioral and deployment claims; conflict with free-entry policy remains a release issue.

https://drive.google.com/file/d/1dVx6rf5uTZoqMRUzKrDTWsYYfzuKRkgl/view

S19 — Football platform blueprint (Repository source). First 210 of 221 source lines reviewed, including architecture, product, tenancy and design contracts.

https://drive.google.com/file/d/1bSZvtg4CC-dPopSShQmXiQrDTTQhpT_q/view

S20 — Route-state evidence registry (Repository source). Current registry has empty cells/groups; not proof that no screenshots exist elsewhere.

https://drive.google.com/file/d/1KkJEsNxovRx5wc2t8-4lAop2kWgtyKCy/view

S21 — Build-evidence bundle registry (Repository source). Current bundles array is empty.

https://drive.google.com/file/d/1XJd-1UsYp-8CKMsBKpW5Cqs_h875Ur2T/view

S22 — Rayon release checklist (Repository source). Freshly read from the current Drive file; not proof of deployment.

https://drive.google.com/file/d/1hfdEnPK4x8_lOxck4PTCGpkQDKpFLi17/view

S23 — Operator API entrypoint (Repository source). Freshly read from the current Drive file; not proof of deployment.

https://drive.google.com/file/d/1J66OJK__n47gsN7cyFadnfW63WewYmnj/view

S24 — Operator console handler (Repository source). Freshly read from the current Drive file; not proof of deployment.

https://drive.google.com/file/d/1fgnPtcoK0sc6T5JVQxg8vAonL1QkuwAJ/view

S25 — Operator gateway configuration (Repository source). Freshly read from the current Drive file; not proof of deployment.

https://drive.google.com/file/d/1tVqsVNYSBDrUHaBUZB9GjjaT65ss5q83/view

S26 — Operator console documentation (Repository source). Names a console-specific entrypoint/configuration not returned in the inspected current source/root folder listings.

https://drive.google.com/file/d/1xZTMg97Hq6fVXwtOgwZZghB8x38wPeCA/view

S27 — Operator Access identity adapter (Repository source). Freshly read from the current Drive file; not proof of deployment.

https://drive.google.com/file/d/1LtG2kIA8_psXzwtNjbEUjtwcFYe29aIm/view

S28 — Installed Cloudflare disposition CSV (Repository source). Seven data rows. Earlier larger archived registers are not silently substituted for this file.

https://drive.google.com/file/d/1PpYe-2H6Ssj1jFJZ3SnL8PFgTq5ewxuU/view

S29 — Offline strategy (Repository source). Contains older navigation terminology; current implementation behavior still needs tracing.

https://drive.google.com/file/d/1MfqXhpuBfw0_UTLl33NdfNU_bbGIekq7/view

S30 — Android signing artifact metadata (Repository source). Metadata only. Contents, validity and secret values were not opened or tested.

https://drive.google.com/file/d/1m8qAjoBhpeD7sopp8Xld0sFMtJw5bN9E/view

S31 — Web environment artifact metadata (Repository source). Metadata only. Contents were not opened; no assertion that every variable is a secret.

https://drive.google.com/file/d/1CkBh6849kWtd8TJ3jLKJgRnr2xuPJdVC/view

S32 — Batch 11 native recovery implementation report (Repository source). Prior delivery evidence, not newly executed native tests.

https://drive.google.com/file/d/1vp1WgODK5ubxzL3JNnRXFcX-keL9xbHZ/view

S33 — Batch 12 iOS recovery implementation report (Repository source). Prior archived delivery, not proof of installation into canonical source or Apple SDK verification.

https://drive.google.com/file/d/15o1Drd2x0ONDhceGwWOuniIikgTZF2DV/view

S34 — Complete conversation archive upload receipt (Repository source). Prior receipt expressly distinguishes archive preservation from individually installed repository files.

https://drive.google.com/file/d/1YqCsDqxWC-b1AbQd69fQfDAPp5NrICLT/view

E01 — Permission metadata observations (This-review observation). Root, keystore file and .env.local each returned anyone/writer. No ACL changes or secret reads.

evidence/drive_permission_observations.json

E02 — Current source versus first implementation archive (This-review comparison). Three current canonical files differ from archived proposed replacements; preserve newer changes when reconciling.

evidence/current_vs_first_implemented_patch.json

E03 — Boundary-validator reproduction (This-review execution). Minimal fixture passes; adding exact current inventory triggers lexical rejection. Not a full CI execution.

evidence/boundary_reproduction.json

E04 — Public Worker and OTP reproductions (This-review execution). Three synthetic tests reproduce mixed freshness, media digest bypass, and global OTP contention.

evidence/current_source_observations.json

E05 — Payment/checkout regression log (This-review execution). 432 tests pass against reconstructed test context with freshly matched service cores.

evidence/payment_suite.log

E06 — Authentication regression log (This-review execution). 77 tests pass against reconstructed test context with freshly matched IdentityService.

evidence/auth_suite.log

E07 — Fresh core comparison and lock consistency (This-review comparison). Three current service cores equal archived context. Dependency root match is not an advisory/security audit.

evidence/fresh_core_archive_comparison.json

W01 — Google Drive permission model (External primary guidance). anyone/writer denotes link-holder write access; allowFileDiscovery controls discovery, not confidentiality.

https://developers.google.com/workspace/drive/api/reference/rest/v3/permissions

W02 — Cloudflare D1 limits (External primary guidance). Database/query/bind limits and single-database sequential execution require capacity tests.

https://developers.cloudflare.com/d1/platform/limits/

W03 — Cloudflare D1 database API (External primary guidance). Batch transaction semantics and session/read-consistency facilities; not cross-database transactions.

https://developers.cloudflare.com/d1/worker-api/d1-database/

W04 — Cloudflare D1 data location (External primary guidance). Location hints are not guarantees; documentation says D1 databases do not run in Africa.

https://developers.cloudflare.com/d1/configuration/data-location/

W05 — Cloudflare Workers testing (External primary guidance). Run runtime-specific tests, not only Node simulations.

https://developers.cloudflare.com/workers/testing/

W06 — Workers Vitest integration (External primary guidance). Current runtime integration guidance; pin compatible packages rather than reusing historical snippets.

https://developers.cloudflare.com/workers/testing/vitest-integration/

W07 — Cloudflare Queues delivery guarantees (External primary guidance). At-least-once delivery requires idempotent effects and recovery.

https://developers.cloudflare.com/queues/reference/delivery-guarantees/

W08 — Cloudflare Access in Workers (External primary guidance). ctx.access is supported; direct invocation and propagation constraints require actual integration testing.

https://developers.cloudflare.com/workers/configuration/cloudflare-access/

W09 — Supabase backups (External primary guidance). Database backups do not contain Storage object originals.

https://supabase.com/docs/guides/platform/backups

W10 — Next.js TypeScript configuration (External primary guidance). ignoreBuildErrors bypasses build checking; enforce an independent type-check before deployment.

https://nextjs.org/docs/pages/api-reference/config/next-config-js/typescript

W11 — OWASP ASVS (External primary guidance). Use a versioned verification baseline; the latest stable listed version is 5.0.

https://owasp.org/www-project-application-security-verification-standard/

W12 — OWASP MASVS (External primary guidance). Mobile verification categories include storage, cryptography, authentication, network and platform controls.

https://mas.owasp.org/MASVS/

W13 — GitHub Actions secure use (External primary guidance). Immutable action pins, least privilege and workflow protection; source workflow is not runtime permissions proof.

https://docs.github.com/en/actions/reference/security/secure-use

W14 — W3C WCAG 2.2 (External primary guidance). Use testable accessibility criteria alongside native assistive-technology testing.

https://www.w3.org/TR/WCAG22/

W15 — Apple App Review Guidelines (External primary guidance). Review white-label submission, minimum functionality, digital/physical payments, privacy and contest policies by applicable section.

https://developer.apple.com/app-store/review/guidelines/

W16 — Apple account deletion guidance (External primary guidance). Account deletion initiation is required for account-creating apps; deactivation alone is insufficient.

https://developer.apple.com/support/offering-account-deletion-in-your-app

W17 — Apple SDK submission minimums (External primary guidance). From 28 April 2026, iOS uploads need iOS 26 SDK or later. This is not the minimum user OS.

https://developer.apple.com/news/?id=ueeok6yw

W18 — Google Play Payments policy (External primary guidance). Classify physical goods/services separately from digital benefits and check regional exceptions at release.

https://support.google.com/googleplay/android-developer/answer/9858738?hl=en

W19 — Rwanda DPP Law, transfer/storage (External primary guidance). Article 48 transfer grounds and Article 50 authorization for foreign storage are distinct.

https://dpo.gov.rw/dpp-law/sharing-transferstorage-and-retention-of-personal-data

W20 — Rwanda DPO registration (External primary guidance). Confirm applicable controller/processor registration; do not infer certificates from code.

https://dpo.gov.rw/dpp-law/registration-of-a-data-controller-and-a-data-processor

W21 — Rwanda DPO foreign storage authorization (External primary guidance). Validate the actual certificate and authorized storage footprint.

https://dpo.gov.rw/services/authorization-to-store-outside-rwanda

W22 — Rwanda DPP scope (External primary guidance). Applies to relevant Rwanda processing and processing of data subjects located in Rwanda.

https://dpo.gov.rw/dpp-law/general-provisions

W23 — Rwanda collection transparency guidance (External primary guidance). Notices cover purpose, recipients, retention, rights and relevant foreign transfers.

https://dpo.gov.rw/guidance/data-subjects/know-your-rights-to-privacy-when-you-are-requested-for-your-personal-data

Appendix C — deliverable and upload status

The report, 130-task workbook/CSV/JSON, source register and new test/evidence bundle are newly created audit deliverables. The Drive connection available for this investigation exposes reads but no upload/create/update action; plugin discovery did not provide a usable write capability. No claim is made that these new audit artifacts have been uploaded. The prior conversation archive remains a separate, previously uploaded preservation artifact. Source files and production permissions were not changed.

Recommended destination after access is restricted: AFRICLUB/output/production-readiness-2026-09-27/. Store the detailed security/evidence material with named access rather than an unrestricted link.